Sapienza University of Rome

Cybersecurity
PhD in Cybersecurity

Practical network defense

Candidate
Candidi
Riccardo

Academic Year 2026

Contents

1 Internet **1**
- 1.0.1 What is internet . . . 1
- 1.0.2 protocols . . . 1
- 1.0.3 Access layer . . . 2
- 1.1 IP . . . 2
  - 1.1.1 IP Addresses . . . 2
- 1.2 Layering . . . 3
  - 1.2.1 TCP/IP model . . . 3

2 iPv6 addressing **4**
- 2.1 IPv6 introduction . . . 4
  - 2.1.1 Link-local addresses . . . 5
  - 2.1.2 SLAAC . . . 5
  - 2.1.3 ICMPv6 neighbor discover protocol . . . 6
  - 2.1.4 multicast addresses . . . 6

3 IPv4 vs IPv6 **8**
- 3.1 IPv6 security . . . 8
- 3.2 associated protocols . . . 9
  - 3.2.1 ICMPv6 . . . 9
  - 3.2.2 NDP . . . 9
  - 3.2.3 MLD . . . 10

4 Traffic regulations **11**
- 4.1 Firewalls . . . 11
  - 4.1.1 Host based packet filters . . . 11
  - 4.1.2 Network access control list . . . 11
  - 4.1.3 Bastion host . . . 12
  - 4.1.4 DMZ . . . 12
  - 4.1.5 defense in depth . . . 12
  - 4.1.6 Packet filers (stateless firewalls) . . . 12
  - 4.1.7 Statefull firewalls . . . 13
  - 4.1.8 Application level filtering (proxy-like) . . . 13
  - 4.1.9 Host based firewalls . . . 13
  - 4.1.10 Circuit level gateways (proxy) . . . 13

5 NAT **14**
- 5.1 Source NAT (SNAT) . . . 14
- 5.2 Basic NAT . . . 14
- 5.3 Network address port translation (NAPT) . . . 15
- 5.4 Destination NAT (DNAT) . . . 15

6 Iptables **16**
6.0.1 MANGLE . . . 16
6.0.2 FILTER . . . 16
6.0.3 NAT . . . 17

7 VPN **18**
7.1 Tunneling . . . 18
7.1.1 site-to-site tunneling . . . 19
7.1.2 Tunneling for VPN . . . 19
7.2 VPN device placement . . . 19
7.2.1 SSL VPN device placement . . . 19
7.2.2 VPN enabled firewall . . . 19
7.2.3 VPN internal . . . 20
7.2.4 DMZ with VPN . . . 20
7.2.5 VPN with two interfaces in DMZ . . . 20
7.3 SSL tunneling . . . 21
7.3.1 SSL e TLS . . . 21
7.3.2 SSL protocol architectures . . . 21
7.3.3 SSL/TLS Handshake protocol . . . 21
7.3.4 Digital certificate and certification authorities . . . 21
7.3.5 SSL/TSL heartbeat . . . 22
7.4 IPsec . . . 22
7.4.1 IPsec modes . . . 22
7.4.2 Authentication Header . . . 23
7.4.3 ESP . . . 23

Bibliography **24**

Chapter 1

Internet

1.0.1 What is internet

Internet is a network of networks. There are hierarcical networks such as:

- Internet backbone: connecting the ISPs' backbones
- ISP backbone: connecting organizations' backbones
- Organization backbone connects local area networks (LANs)
- LAN connects end systems

Internet is diveded in:

- Access network: connects end systems to the first router (e.g., DSL, cable, fiber, wireless)
- Physical media: carries signals between devices (e.g., twisted pair, coaxial cable, fiber optic, radio waves)
- Network core: connects the access networks (e.g., routers and links). Routers work togheter to figure a path for each packet from source to destination. The routing table are mantained in real time and a routing algorithm can adapt to changing internet conditons.

1.0.2 protocols

Protocols specify rules about the service, such as:

- procedure rules: types and sequence of messages exchanged, syntax and semantics, action to take in respect of messages and events
- message format size and coding
- timing to wait between events, timeouts, flow control

1.0.3 Access layer

Its constituted by network with end points of the same local management, provides connectivity among station on the same network and they can comunicate directly among them.

Ethernet(IEEE 802.3) is the most common access control protocol. Each host has a NIC (Network Interface Card) with a fixxed address. MAC addresses are 48bits long and uniquely identify the host in the network. Each ethernet frame has a fixed format.

Figure 1.1: Ethernet Frame Format

All the host connected to the same transmission system are a nework. An ethernet network costitutes a brodcast domani, where, ideally, frames sent in that domain are recived by all the host. Switches limit the explosion of the packets. Only the brodcast messages are replicated. Switches remembers the sourca MAC address on different ports. They only replicate the frame on the segment where the MAC address replies. Ethernet is inefficent in large network, as it uses brodcasst packets.

1.1 IP

1.1.1 IP Addresses

There are two version of IP: IPv4(32bit) and IPv6(128bit).

There are three types of IP addresses:

- Unicast: identifies a single host on the network
- Multicast: identifies a group of hosts on the network
- Broadcast: identifies all hosts on the network

there are classes of IP addresses:

- Class A: 24 bit for host.
- Class B: 16 bit for host.
- Class C: 8 bit for host.
- Class D: Used for multicast addressing.
- Class E: Reserved for future use.

There are routable and non routable IP addresses. The routable have to be unique on the internet, whike non routable can exist in different network but can not be used on internet.

1.2 Layering

the comunication between hosts in the network is organized in task assigned to a layer. Each layer offers a service to the layer above and uses the services of the layer below. the data is trasfered from the application level to application level over a network. Each layer adds protocol information and data to the layer below. The physical layer send the data physically to the destination. In the destination, the phisical layer sends the data up the stack. Each protocol reads the appropriate protocol information ad forward the data to the layer above.

There are 2 main layering models:

- ISO/OSI model: 7 layers (Physical, Data Link, Network, Transport, Session, Presentation, Application)
- TCP/IP model: 4 layers (Link, Internet, Transport, Application)

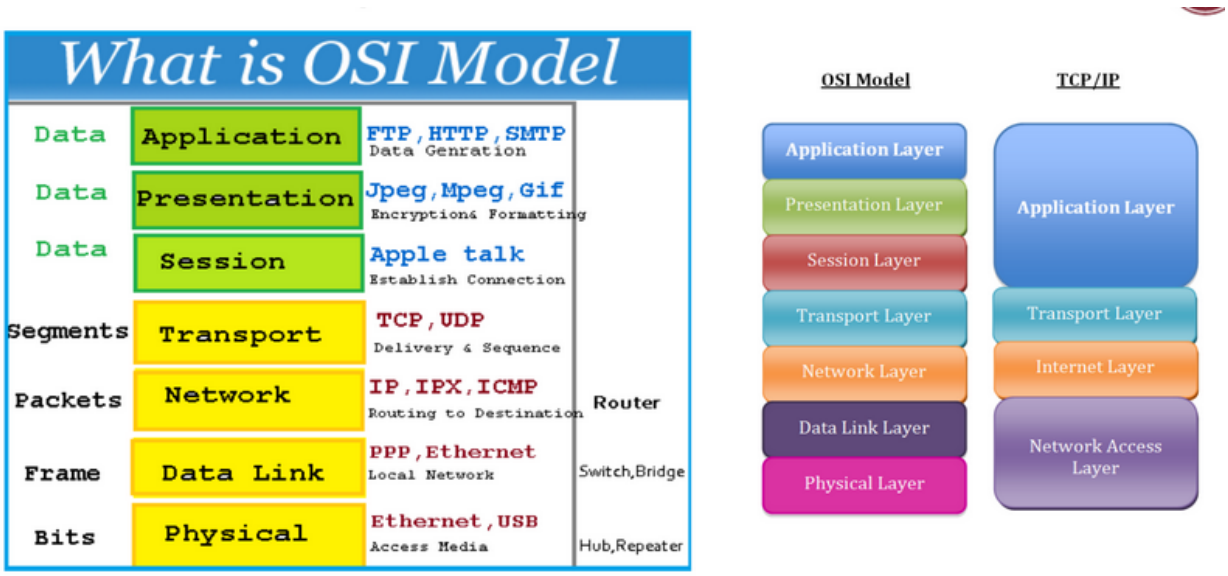

Figure 1.2: Models

1.2.1 TCP/IP model

- application layer: Corresponds to the top three layers of the OSI model.(Protocols: SMTP (sending e-mail), HTTP (web), FTP (file transfer), and others). Address: internet name (e.g., www.google.com)
- Transport layer: Equivalent to Layer 4 (Transport) of the OSI model.(Protocols: TCP, UDP). Address: port number (e.g., 80 for HTTP)
- Internet: Equivalent to layer 3 (network) of the OSI model.(Protocols: IP, ICMP, IPSec). Address: IP address (e.g., 192.168.1.1)
- Datalink: Equivalent to layer 2 (data link) of the OSI model.(Protocols: Ethernet, WiFi, ARP, etc.). Address: MAC address (e.g., 00:0a:95:9d:68:16)
- Physical layer: Equivalent to Layer 1 (Physical) of the OSI model.

Chapter 2

iPv6 addressing

2.1 IPv6 introduction

Developed in the 90s, written in exadecimal, has 128-bit addresses. It has stateless autoconfiguration, end-to-end reachability eithout using NAT, support for mobility, easy peer to peer networking.

iPv6 does not use NAT. NAT has been used to hide customers, but it creates some issues, like peer to peer networking.

iPv6 addresses are 128 bit repreented in hexadecimal and has the following format:

- 1 hex digit = 4 bit
- 8 groups of 4 hex digits between 0000 and FFFF
- groups are separated by colons
- leading zeros in a group can be ommited
- one or more consecutive groups of zeros can be replaced with a double colon (::)

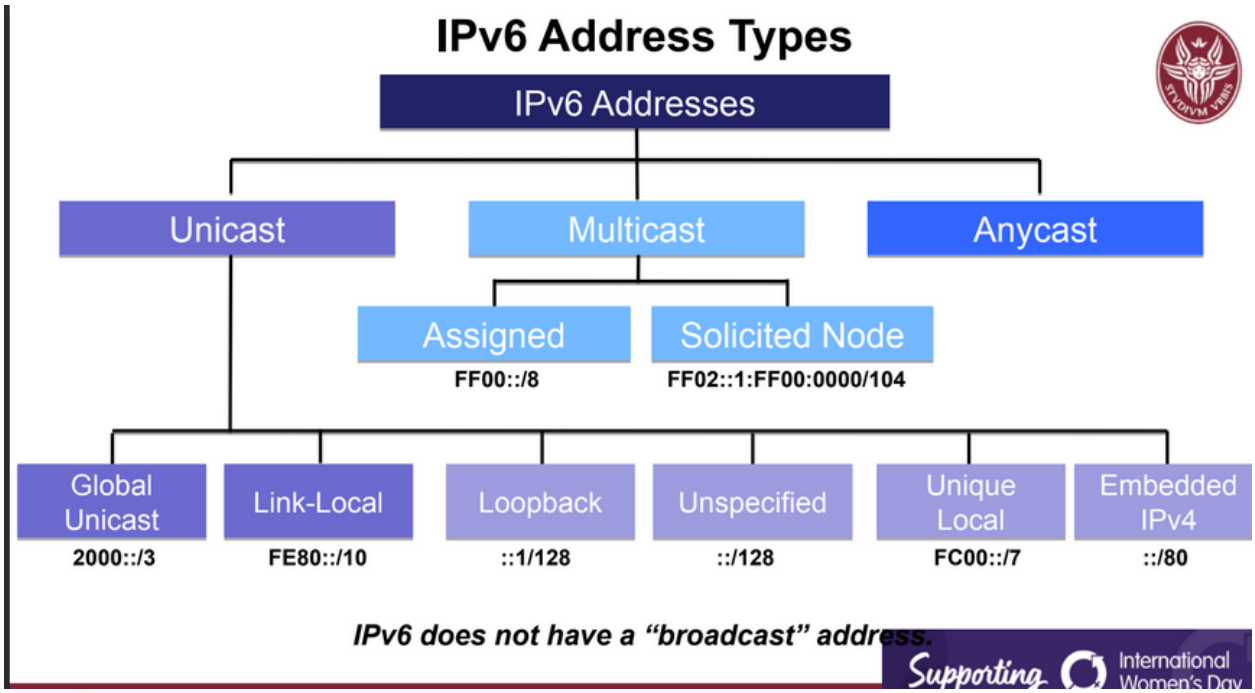

Figure 2.1: IPv6 address format

- IPv6 source: always a unicast (link local or GUA)
- IPv6 destination: unicast, multicast, or anycast
- Global Unicast Address (GUA): globally routable and reachable on the IPv6 internet. It has the following format: 2000::/3 (first 3 bits are 001). The next 45 bits are the global routing prefix, assigned by IANA to RIRs. The next 16 bits are the subnet ID, used to identify subnets within an organization. The last 64 bits are the interface ID, used to identify an interface on a subnet.
- prefix: equivalent to the network address of an IPv4 address
- prefix length: equivalent to the subnet mask of an IPv4 address
- interface ID: equivalent to the host address of an IPv4 address

2.1.1 Link-local addresses

Used to comunicate with other devices on the link. Not routable off the link, only have to be unique on the link. Not included in the IPv6 routing table. An ipv6 devise has at least one local link address.

The router link local is used as the default gateway. Routers exchange routing messages and use the link local address as next hop address in the routing

2.1.2 SLAAC

Stateless Address Autoconfiguration (SLAAC) allows a host to automatically configure its own IPv6 address without the need for a DHCP server. The host generates its own interface ID and

combines it with the network prefix obtained from the router advertisement messages to create a unique IPv6 address.

The idea is to rovide additional addresses with short lifetime and using themm as source address when originating connections. Same prefix as a ublic address, randomized value for interface ID. It is common to have multiple temporary addresses to make sure existing connections continue while a new temp address is created for a new connection.

2.1.3 ICMPv6 neighbor discover protocol

ICMPv6 Neighbor Discovery defines 5 different packet types:

- Router Solicitation Message
- Router Advertisement Message
- Neighbor Solicitation Message
- Neighbor Advertisement Message
- Redirect Message

When a host want an IPv6 address, it sends a Router Solicitation message to the all-routers multicast address. The router responds with a Router Advertisement message- There are 3 types of Router Advertisement messages:

- Option 1: SLAAC, No DHCPv6 "I'm everything you need (Prefix, Prefix-length, Default Gateway)"
- Option 2: SLAAC + Stateless DHCPv6 for DNS address "Here is my information but you need to get other information such as DNS addresses from a DHCPv6 server." (DNS can be in RA)
- Option 3: All addressing except default gateway use DHCPv6 "I can't help you. Ask a DHCPv6 server for all your information."

2.1.4 multicast addresses

Multicast addresses are used to send a packet to multiple destination simultaneously. There are two types of multicast addresses: Assigned and Solicited-node.

Multicast address have the prefix FF00::/8. they use a 4 bits field to define the range of the multicast packet, called scope:

- 0: reserved
- 1: interface-local scope (packets are only valid on the same interface)
- 2: link-local scope (packets are only valid on the same link
- 5: site-local scope (packets are only valid within the same site)
- 8: organization-local scope (packets are only valid within the same organization)

- E: global scope (packets are valid on the entire internet)

4 bits are used to define the flags:

- 0: permnent, well known multicast address
- 1: transient, dynamically assigned multicast address

Chapter 3

IPv4 vs IPv6

- version: Ipv4 contains 4, IPv6 contains 6
- internet header lenght(IHL): ipv4 has a 32 bit field including any options or padding, ipv6 has no IHL, his header is fixed at 40bytes
- ipv4 has "type of service" field, ipv6 has "traffic class" field
- ipv6 has "flow label" field to identify packets in common stream or flow, ipv4 has no equivalent
- ipv4 has 16 bit "total length" field, ipv6 has 32 bit "payload length" field
- ipv4 uses fragmentation, ipv6 does not use fragmentation, the source host is responsible for fragmentation
- ipv4 protocol, ipv6 next header
- ipv4 TTL, ipv6 hop limit
- ipv4 header checksum, ipv6 has no header checksum
- ipv4 has options and padding, ipv6 has extension headers. Next headers identify the protoco carried in the data portion of the packet

3.1 IPv6 security

IPv6 is not more secure than IPv4 and its security is built in. Even if there is no NAT in IPv6, it is possible to use firewalls to filter traffic and you are not exposed to attacks from the internet. IPv6 is resilient aganinst brute force scanning, but there are other scanning techniques.

There are lots of threats to IPv6, such as:

- IP spoofing: using a fake ip source address. Solution: ingress filtering, egress filtering, unicast reverse path forwarding (uRPF)
- using traffic clas or flow label to bypass security devices. Solution: firewall should inspect traffic class and flow label fields

- routhing header(Includes one or more IPs that should be “visited” in the path) attacks: using extension headers to bypass security devices. Solution: firewall should inspect extension headers
- fragmentation attacks: using fragmentation to bypass security devices. Solution: firewall should inspect fragments and reassemble them before inspection

3.2 associated protocols

3.2.1 ICMPv6

Provides error messages and informational messages. It is used for error reporting, diagnostics, and neighbor discovery. It is an integral part of the IPv6 protocol suite and is used for various functions such as path MTU discovery, router advertisement, and neighbor solicitation.

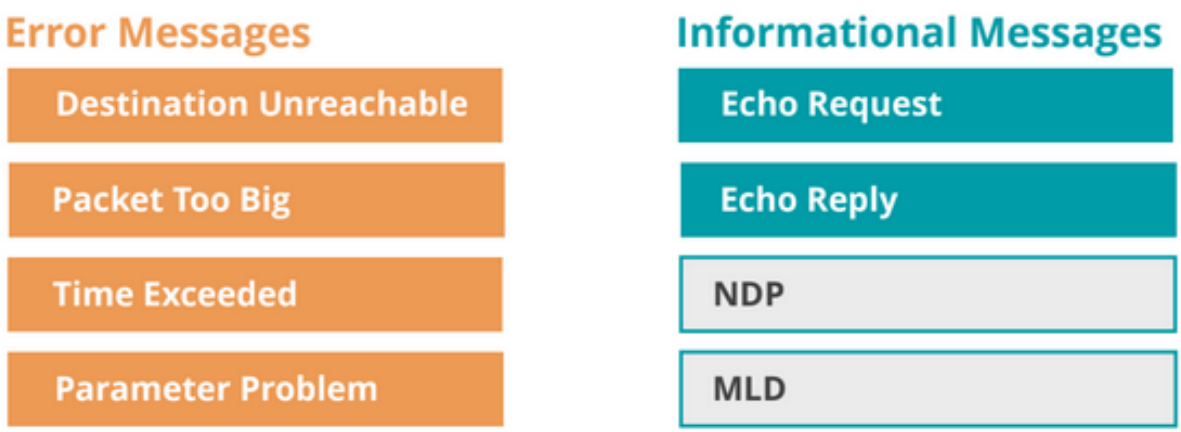

Figure 3.1: ICMPv6 message types

3.2.2 NDP

Used on a link to discover other devices, their link-layer addresses, and to maintain reachability information about the paths to active neighbors. It is used for address autoconfiguration, address resolution, neighbor unreachability detection, and router discovery.

NDP threats include:

- Neighbor solicitation/advertisement spoofing: an attacker can send fake neighbor solicitation or advertisement messages to redirect traffic or cause a denial of service. Solution: use secure neighbor discovery (SEND) which uses cryptographic methods to authenticate messages.
- Redirection/DOS attacks: an attacker can send fake redirection messages to redirect traffic or cause a denial of service. Solution: use SEND to authenticate messages.
- Man-in-the-middle attacks: an attacker can intercept and modify neighbor discovery messages to redirect traffic or cause a denial of service. Solution: use SEND to authenticate messages.

3.2.3 MLD

MLD (multicast listener discovery) is used on local link, uses ICMP, required by NDP. IPv6 nodes use it when joining a multicast group

Chapter 4

Traffic regulations

4.1 Firewalls

A firewall is a device that acts like a router and implements rules to determine if packets are allowed to travel from one network to another. they restrict access from outside prevents attackers from getting too close and restrict people from leaving. To attain a certain level of security you can: regulate traffic allowed, protect the traffic using encryption, monitor traffic and hosts for "bad behaviour".

firewalls rules/proprieties:

- Least privilege
- Defense in depth
- choke point
- weakest links
- fail-safe stance
- universal partecipation
- diversity of defense
- simplicity

4.1.1 Host based packet filters

A kind of firewall that disciplines traffic in/out a single host, specifies the packets that can be received and sent. Usually each installed application has a known policy that has to obey

4.1.2 Network access control list

Lists the rights for accessing or using networks (used in routers, switches and firewalls). Usually distinguish between incoming and outgoing traffic, per interface/port. Each packet is treated independently, without any knowledge of what has come before.

4.1.3 Bastion host

hardened computer used to deal with all traffic coming a protected network from the outside. Hardening is the task of re reducing or removing vulnerabilities in a computer system:

- remove unnecessary software
- remove unnecessary services
- remove unnecessary accounts
- apply patches and updates
- use strong authentication and access control
- use encryption to protect data in transit and at rest
- monitor and log activity on the system

4.1.4 DMZ

DMZ stands for demilitarized zone: Computer host or small network inserted as a neutral xone between a company private network and the outside public network. Network construct that provides secure segregation of networks that host services for users visitors or partners. DMZ is a necessary method of providing a multilayered defense in depth approch to security. It reduces and regulate the access to internal(private) components of the IT system.

4.1.5 defense in depth

A security approach in wich IT systems are protected using multiple overlapping systems. It adds redundancy to the defensive measures, it aims to remove single point of failures it finds the right balance between complexity and multiplicity of defense mechanism. In order to compromise a system, an attacker has to find multiple vulnerabilities in different components.

4.1.6 Packet filers (stateless firewalls)

Drop packets based on source/destination addresses or port numbers or flag. Can operate on incoming and outgoing traffic. It checks packets with fake id addresses. It operates in data link, network and transport layer. Problem with packet filters:

- Only a small numbers of parameters: it's easy to specify filtering rules that are too specific or too general
- Payload of TCP is not inspected: there is no protection against attacks based on upper level vulnerabilities.
- limited logging ability
- no authentication facilities
- suscetible to attacks based on vulnerabilities in various implementation of TCP/IP

4.1.7 Statefull firewalls

statefull inspection firewalls can keep track of established connections. Thet can drop packets based on their source or destination IP addresses, port numbers and TCP flags. In this way they solve one major problem of simple packet filters, since they can check that incoming traffic from a high-numbered port is a genuine response to an outgoing request. It operates in data link, network and transoprt level.

4.1.8 Application level filtering (proxy-like)

Deals with the details of services. Needs a separate special purpose mechanism for each application Can support user to gateway authentication.

4.1.9 Host based firewalls

A firewall on each individual host to protect that one machine. Selectively enable specific services or ports that will be used to send and recive raffic. It plays a big part in reducing what is accessible from outside and protecting the other element of the system if one is compromised.

4.1.10 Circuit level gateways (proxy)

Also known as TCP relay. The clients connect to a proxy that relays its connection in a protocol independent manner. Provides user authentication. Usually with no content filtering.

TCP relay splices and relay TCP connection. It does not examine content of TCP segments, can use ACL(like packet filtering) and has less controll than application level gateway.

Chapter 5

NAT

NAT (Network address translation) translate the address, connecting a LAN to the internet using un-routable in-house LAN addresses. In a routed firewall, NAT can filter request from hosts on WAN side to hosts in LAN side, allows host rewuest from LAN side to reach WAN side, and hide LAN host to external port scan.

Routable addresses have to be unique on the internet to be reachable. Non routable addresses are not reachable from the internet.

NAT goals:

- a private network uses just one IP address provided by ISP to connect to the internet
- private network use private IP addresses provided by IETF
- can change address of devices in private network without notifyng outside world
- can changhe ISP without changing the addresses of devices in prvate network
- Devies inside private network are not explicitly addressable by external network, or visible by outside world.

5.1 Source NAT (SNAT)

translate outgoing IP source packet headers from the internal host addresses to the WAN ip address. The session is masqueraded as coming from NAT device.

The firewall/router forwards replies from the client service request by the external server to the client. Enables the client-server session or connection to continue on another port as requested by the extrnal server, forwarding any responses by the server to the client.

The NAT table is where associations between request and internal IP addresses are kept.

5.2 Basic NAT

a block of external/public IP addresses are set aside for translating the addresses of hosts within a private domain as they originate sessions to the external domain. However, ultiple IP address are difficult to obtain.

5.3 Network address port translation (NAPT)

Multiplex a number of private hosts into a single external/public IP address. The IP address binding extends to transport level identifiers such as TCP/UDP ports. NAPT router blocks all incoming ports by default. Many application have had problems with NAPT in their handling of incoming request.

5.4 Destination NAT (DNAT)

Enables destination servers inside a firewall or router LAN to be accessed by clients located outside. The service appears to be hosted by the firewall/router.

The firewall/router uses NAT table to: Translate incoming packets from the firewall/router WAN IP address to the internal address of the server. Forward the replies to the client service request from the internal server to the external client. Enables the client-server session or connection to continue on another port as requested by the internal server, forwarding any responses by the client to the server

Chapter 6

Iptables

Foundamentals:

- rules are grouped in "tables"
- Each table has different "chains" of rules and different possible "targets"
- Each packet is subjected to each rule of a chain
- packet fates depend on first matching rule

Built in tables:

- filter: default table, used for filtering packets
- nat: used for network address translation
- mangle: used for specialized packet alteration
- raw: used for configuring exemptions from connection tracking

6.0.1 MANGLE

Used for IP header manipulation (should not be used for filtering or NAT). Five chain to alter

- PREROUTING: for altering incoming packets before routing
- INPUT: for altering packets destined for local sockets
- FORWARD: for altering packets being routed through the box
- OUTPUT: for altering locally generated packets before routing
- POSTROUTING: for altering packets as they are about to go out

6.0.2 FILTER

Used for filterning packets. Three built in chains:

- INPUT: for packets destined for local sockets
- FORWARD: for packets being routed through the box
- OUTPUT: for locally generated packets

6.0.3 NAT

Used for NAT to translate the packets source field or destination field. (only the first packet of a stream will hit this table, the others will have the same action)

Special targets:

- DNAT: for altering destination IP address (PREROUTING and OUTPUT)
- SNAT: for altering source IP address (POSTROUTING)
- MASQUERADE: for dynamic SNAT (POSTROUTING)
- REDIRECT: for altering destination IP to localhost (PREROUTING)

Chapter 7

VPN

A virtual network built on top of another network infrastructure, wich can provid a secure comunication mechanism for data and other information transferred between two endpoints. Usually based on the use of encryption.

It has the following safety goals:

- confidentiality: protect data from unauthorized access
- integrity: ensure that data is not tampered with during transmission
- authentication: verify the identity of the parties involved in the communication
- replay protection: prevent attackers from intercepting and reusing data packets
- access control: restrict access to the VPN network to authorized users only
- traffic analyis resistance: make it difficult for attackers to analyze the traffic patterns of the VPN network

It has the following usability goals:

- Transparency: the VPN should be transparent to users and applications, allowing them to use the network as they normally would without any special configuration or changes.
- flexibility: the VPN should be flexible enough to support a wide range of use cases and network configurations, including remote access, site-to-site connectivity, and cloud-based deployments.
- simplicity: the VPN should be easy to set up and manage, with a user-friendly interface and clear documentation.

7.1 Tunneling

Operation of a network connection on top of another network connection, allows two host or sites to communicate through another network that they do not want to use directly.

7.1.1 site-to-site tunneling

Enables a PDU to be transported from one site to another without its content being processed by hosts on the route. The idea is to incapsulate the whole PDU in another PDU sent out on the network connecting the two sites. This host-to-host communication does not need to use IP

7.1.2 Tunneling for VPN

tunneling offers the basic methods for providing VPN. There are two main VPN modes:

- split tunneling: Some traffic goes through tunnel, other traffic uses remote user's default gateway
- full tunneling: All traffic goes through tunnel

7.2 VPN device placement

7.2.1 SSL VPN device placement

Device placement is a challenge because it affects security, functionality and performance. The main options for placement are:

- VPN functionality on the firewall: VPN functionality is integrated into the firewall, providing a single point of management and security. However, this can create a single point of failure and may not be suitable for high-traffic environments.
- VPN device in internal network: The VPN device is placed within the internal network, providing better performance and security. However, this can create a potential security risk if the VPN device is compromised.
- Single interface VPN device in DMZ: The VPN device is placed in the DMZ, providing a balance between security and performance. However, this can create a potential security risk if the VPN device is compromised.
- Dual interface VPN device in DMZ: The VPN device is placed in the DMZ with two interfaces, providing better security and performance. However, this can create a potential security risk if the VPN device is compromised.

7.2.2 VPN enabled firewall

The VPN device communicates directly with internal hosts.

Advantages:

- NO holes in FW between VPN device and internal hosts
- Traffic between device and internal network must go through FW.
- simple network administration since only one box to administer

Disadvantages:

- Limited to VPN functionality offered by FW vendor.
- FW directly accessible to external users via port 443.
- Adding VPN functionality to FW can introduce vulnerabilities.

7.2.3 VPN internal

Advantages:

- Only single rule for single address to be added to FW.
- No “holes” needed in FW between VPN device and internal network.
- VPN traffic is behind FW, so protected from attacks by machines in DMZ.

Disadvantages:

- VPN traffic passes through FW on tunnel, so it is not analyzed.
- Unsolicited traffic can be sent into internal network from outside to internal VPN device.
- Internal network is compromised if VPN device is compromised

7.2.4 DMZ with VPN

Advantages:

- Internal network protected against compromised VPN device.
- Traffic between device and internal network must go through FW.
- IDS in DMZ can analyze traffic destined for internal network.

Disadvantages:

- Numerous ports open in FW between device and internal hosts.
- Decrypted traffic from device to internal network must be sent through DMZ.
- FW bypassed when user traffic is destined for hosts in DMZ.

7.2.5 VPN with two interfaces in DMZ

Clients connect to external device interface, internal traffic uses internal interface.

Advantages:

- All advantages of placing VPN device DMZ.
- Unencrypted traffic to internal hosts is protected from other hosts in DMZ.
- Only FW interface connected to device’s internal interface needs to permit traffic from VPN device.

Disadvantages:

- Numerous ports open in FW between device and internal hosts.
- May introduce additional routing complexity.
- FW bypassed if split tunneling is not used and user traffic is destined for hosts in DMZ

7.3 SSL tunneling

7.3.1 SSL e TLS

Secure sockets layer (SSL) and transport layer security (TLS) are one of the most widely used security services.General-purpose service implemented as a set of protocols that rely on TCP. SSL applies security in the transport layer, placed on top of TCP, so no need to change TCP/IP stack or OS. Provides secure channel. Optional server authentication with public key certificates.

7.3.2 SSL protocol architectures

Adds extra layer between T and A layer, adding extra elements to A layer.

Record Protocol: Protocol offering basic encryption and integrity services to applications

Application Protocols: control operation of the record protocol: Handshake: Used to authenticate server (and optionally client) and to agree on encryption keys and algorithms. Change cipher spec: Selects agreed keys and encryption algorithm until further notice. Alert: Transfers information about failures.

7.3.3 SSL/TLS Handshake protocol

4 phases:

- Hello: Establishment of security capabilities: Client sends list of possibilities, in order of preference. Server selects one, and informs Client of its choice. Parties also exchange random noise for use in key generation.
- Server authentication and key exchange: Server executes selected key exchange protocol (if needed). Server sends authentication info. (e.g. X.509 cert.) to Client.
- Client authentication and key exchange: Client executes selected key exchange protocol (mandatory). Client sends authentication info. to Server (optional).
- Finish: Shared secret key is derived from pre-secrets exch. in 2, 3. Change Cipher Spec. protocol is activated. Summaries of progress of Handshake Protocol are exchanged and checked by both parties.

7.3.4 Digital certificate and certification authorities

digital certificate are documents that certifie the relation between a public key and its owner. to verify them we need a public key that we trust. Trusted public keys are stored in certificates of certification authorities (CA). CA are organizations that issue digital certificates and perform vary task, such as:

- Receive application for keys.
- Verify applicant's identity, conduct due diligence appropriate to the trust level, and issue key pairs.
- Store public keys and protect them from unauthorized modification.
- Keep a register of valid keys.
- Revoke and delete keys that are invalid or expired. Maintain a certificate revocation list (CRL).

Certificates of CAs are stored in any computer that want to use internet securely.

Certification authorities are organized in a hierarchy, called Public Key Infrastructure. To verify a certificate, one needs to verify all the signatures up to the top of the hierarchy

7.3.5 SSL/TSL heartbeat

It is an extension (RFC 6520) that allows to keep an established session alive To avoid the re-negotiation of the security parameters for establishing a secure session, we can keep using the same parameters even if there is no exchange of data It introduces two messages: HeartbeatRequest and HeartbeatResponse When one endpoint sends a HeartbeatRequest message to the other endpoints, the former also starts what is known as the retransmit timer An SSL/TLS session is considered to have terminated in the absence of a HeartbeatResponse packet within a time interval. As a protection against a replay attack, HeartbeatRequest packets include a payload that must be returned without change by the receiver in its HeartbeatResponse packet.

7.4 IPsec

A network layer protocol suited for providing security over ip, part of IPv6, add on for IPv4. Can handle all three possible security architectures (gateway to gateway, host to gateway, host to host). There are basic function, provided by separate sub-protocols: Authentication header(AH) supports data integrity and authentication of IP packets, Encapsulated security payload(ESP) provides support for encryption and authentication, Internet Key Exchange(IKE) supports for key management.

IP security association: an IPsec connection with all the paramethers needed, like crypto algorithms, key lenghts etc. Both sides must agree on the SA for the comunication to work. For a two way communication, two SA must be defined, and the parameters are negotiated between sender and reciver before the comunication start.

Each SA is identified by: Security parameter index(32 bit integer chosed by sender), destination address, security protocol identifier.

7.4.1 IPsec modes

Transport mode: Provides protection for a T-layer packet embedded as payload in an IP packet.

tunnel mode: Provides protection for an IP packet embedded as payload in an IP packet.ù

7.4.2 Authentication Header

AH header is inserted after the outermost ip header.

One of the (many possible) IP header fields. Contains:

- Next Header: Type of following header field.
- Payload Length: (Length - 2), in 32-bit words, of AH.
- SPI: Identifies SA in use.
- Sequence Number: Monotonically increasing packet counter value.
- Authentication Data (AD): (variable length) HMAC based on MD5 or SHA-1 criptorgraphic hashing algorithm, or AES-CBC, evaluated over:

Immutable fields do not change as the packet traverses the network,Mutable but predictable fields may change, but can be predicted,Mutable, unpredictable fields include Time-to-live, Header checksum.

7.4.3 ESP

ESP header inserted after the outermost IP header depending on whether Transport or Tunnel mode is used: Padding is added to end of T-layer payload to give (a certain amount) of traffic analysis protection. ESP trailer and (optional) ESP authentication field added after the end of the padded T- layer payload. As usual, authentication/integrity does not cover any mutable, unpredictable header fields.

Encrypthion and authentication can be achived by:

- ESP with Authentication. First apply ESP to data, then add AH field.
- Transport Adjacency. Use bundled SAs, first ESP, then AH.
- Encryption covers original IP payload. Authentication covers ESP + original IP header, including source and destination IP addresses
- Transport-Tunnel bundle. Used to achieve authentication before encryption, for example via inner AH transport SA and outer ESP tunnel SA.
- Authentication covers IP payload + IP immutable header. Encryption is applied to entire authenticated inner packet.

Bibliography